Semester Project

Project Selection & Initial Secure Development Plan

Secure Software Development (SSD) | Submission date: 28 September 2026

Part 1 - Group Information

Member	Name	Roll No.
Student 1	Abdul Wahab	23F-3043
Student 2	Ahmad Fareed	23F-3008
Group / Project Name	KisanMandi (Farmer Marketplace with Price Transparency)	-

Part 2 - Selected System

KisanMandi - Farmer Marketplace with Price Transparency. A web platform where verified farmers list crops directly, buyers place sealed bids, market officers publish reference prices and price history, and transport providers deliver orders - reducing dependence on middlemen and making prices fair and visible.

Part 3 - Identify the Problem

Question	Answer
What problem exists?	Many Pakistani farmers sell through middlemen and commission agents at the mandi. They often do not know the current market price, receive low or delayed payments, and cannot reach buyers directly. Buyers, in turn, struggle to find quality produce and compare prices. Bidding in physical markets is opaque, price manipulation and collusion are easy, and farmers' phone numbers and locations are freely shared, exposing them to pressure and fraud.
How will the system address it?	A central platform for verified farmers and buyers: farmers list crops with quantity, quality photos and a minimum price; buyers place sealed bids until a deadline; the highest valid bid wins and an order with delivery tracking is created. Market officers publish reference prices and an append-only price history, so farmers can judge offers. Contact details are revealed only after an order is confirmed, and all actions are logged.
Who will benefit?	Small and medium farmers, buyers (traders, retailers, food processors), transport providers, and agriculture/market departments that want transparent price data.

Part 4 - Users and Roles

No.	User / Role	Main Responsibility
1	Farmer	Registers, lists crops with quantity, quality and minimum price, reviews bids, accepts orders and confirms delivery.
2	Buyer (trader / retailer / processor)	Searches listings, places sealed bids, confirms orders, pays and rates the farmer.
3	Market Officer	Verifies farmers and buyers, publishes reference prices, reviews suspicious activity and resolves disputes.
4	Transport Provider	Views assigned delivery jobs, updates pickup and delivery status, uploads delivery proof.
5	System Administrator	Manages accounts and roles, configures the system, reviews audit logs and security incidents.

Part 5 - Core Modules

No.	Module	Description
1	Registration & Verification	Account creation, phone OTP verification, CNIC/business checks, officer approval, roles.
2	Crop Listing & Sealed Bidding	Farmers create listings with photos; buyers place bids that stay hidden until the deadline.
3	Price Transparency	Reference prices and append-only price history per crop and district.
4	Orders, Contracts & Delivery	Winning-bid order, digital agreement, transport assignment and delivery tracking.
5	Payment Confirmation & Disputes	Record and confirm payments, ratings, dispute reporting and officer resolution.
6	Notifications, Admin & Audit	SMS alerts, user management, tamper-evident audit-log viewer.

Part 6 - Important Information / Assets

Asset / Information	Why is it important?
Farmer personal data (CNIC, phone, farm location)	Exposure lets middlemen pressure farmers, steal produce or commit identity fraud.
Login credentials and OTP codes	Account takeover would let an attacker list fake crops, place bids or redirect payments.
Sealed bids and offer amounts	Confidentiality until the deadline is what makes bidding fair; early leaks enable collusion and undercutting.
Crop listings and quality photos	Integrity matters: fake or altered listings mislead buyers and damage trust in the marketplace.
Price history and reference prices	If manipulated, farmers can be tricked into underpriced sales and the whole market loses trust.
Orders, contracts and delivery records	Proof of who agreed to what; needed to settle disputes and detect fraud.
Payment references and confirmations	Financial data; tampering can hide non-payment or create false payment claims.
Audit logs	Only reliable record of who did what; deletion would hide manipulation and insider abuse.

Part 7 - Initial Security Requirements

1. The system shall authenticate every user with phone OTP verification and store passwords only as salted, strong hashes.
2. The system shall enforce role-based access control so each role can access only the data and actions its duties require (least privilege).
3. The system shall keep bid amounts confidential until the bidding deadline and reveal them only according to the auction rules.
4. The system shall enforce bidding deadlines and minimum prices on the server using server time, and reject bids that violate them.
5. The system shall reveal a farmer's phone number and location to a buyer only after an order is confirmed.
6. The system shall verify ownership on every request so a user cannot view or modify another user's listings, bids or orders.

7. The system shall store price history as append-only records and log every change of a market officer's reference price.

8. The system shall detect and flag suspicious bidding patterns (e.g., repeated bids from linked accounts) for officer review.

9. The system shall validate and sanitize all input on the server and accept only permitted image types and sizes for crop photos.

10. The system shall protect all communication with HTTPS, rate-limit OTP and login attempts, expire idle sessions, and log all critical actions in an audit log.

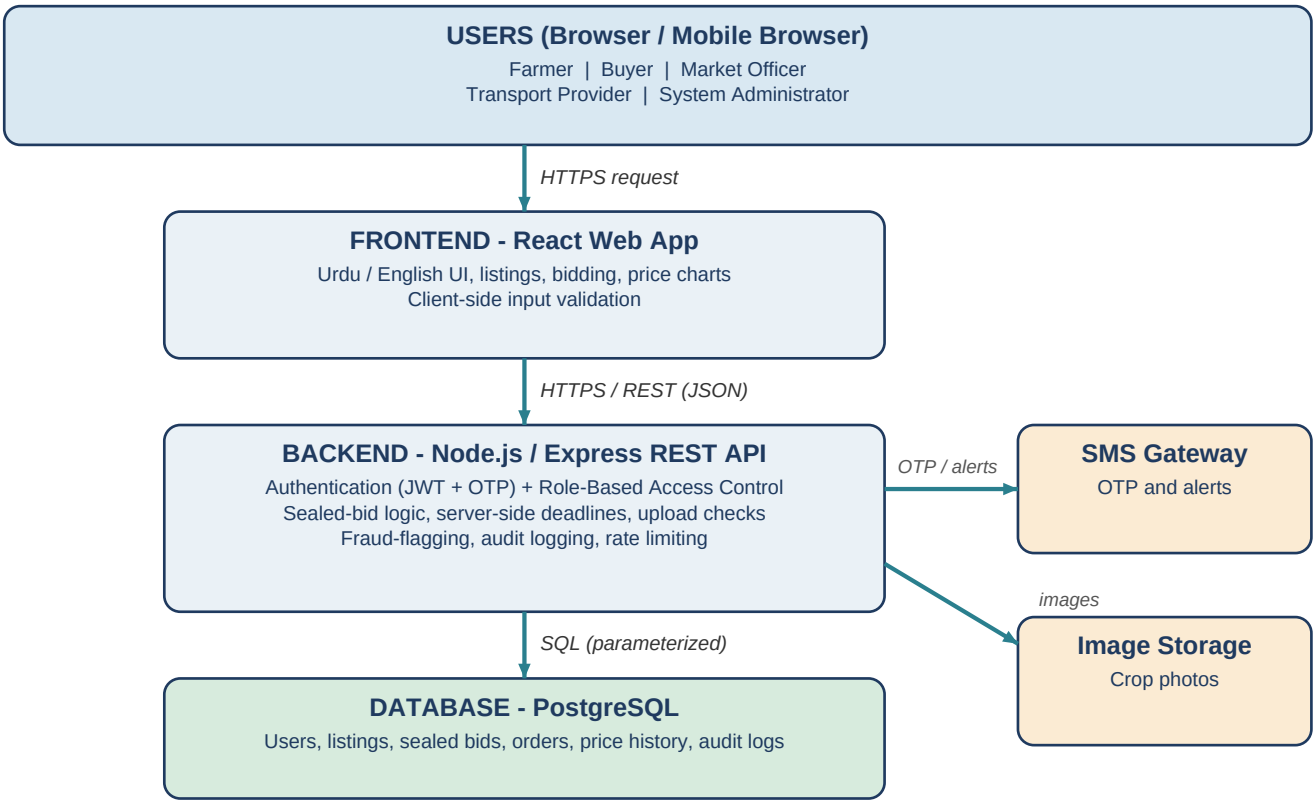
Part 8 - What We Will Build

Must-Have Features	Optional Features
1. Registration, login with OTP, and role-based access control (5 roles). 2. Crop listing with photos, quantity and minimum price. 3. Sealed bidding until the deadline, winner selection and order confirmation. 4. Market reference prices and price history display. 5. Delivery status tracking, audit logging and admin panel.	1. SMS notifications for bids, orders and delivery. 2. Urdu/English language toggle with a simple mobile-friendly UI. 3. Buyer/farmer ratings and reviews. 4. Weather and crop advisory alerts. 5. Map view of listings and delivery routes.

Part 9 - Technology Stack

Layer	Technology
Frontend	React.js with HTML5 / CSS3 (Tailwind CSS), mobile-first design
Backend	Node.js with Express.js (REST API)
Database	PostgreSQL
Other Technologies / Tools	JWT sessions, bcrypt, OTP via SMS gateway (mock service for development), Multer for image uploads, Helmet, express-validator, rate limiter, Git/GitHub, Postman, OWASP ZAP

Part 10 - Basic System Architecture



Flow: User -> React Frontend -> (HTTPS) Backend API -> Database. The backend sends OTPs and alerts through an SMS gateway and stores crop photos in separate image storage. Bid confidentiality, deadlines and all access control checks are enforced on the backend, never in the browser.

Part 11 - Think Like a Security Analyst

Possible Problem	What could happen?
Shill bidding / bid manipulation	Linked accounts place fake bids to push prices up or drive genuine buyers away; leaked sealed bids enable collusion.
Price history manipulation	Fake trades or edited records distort reference prices so farmers accept underpriced offers.
Broken access control / IDOR	A user changes an ID in the URL to view another farmer's phone number, listing details or a competitor's bid.
Contact scraping by middlemen	Bots harvest farmers' phone numbers and locations to pressure them into selling cheaply outside the platform.
Account takeover via OTP abuse	SIM swap, OTP interception or brute force lets an attacker take over a farmer's account and redirect payments.
Fake listings / buyer non-payment	Fake buyers win auctions and vanish, or fake sellers list non-existent crops to collect deposits.

Part 12 - Project Security Development Tracker

Security Topic	Where can it be applied in our project?	What will we implement?	Status
Security Properties	Sealed bids, price history, farmer contact data, audit logs.	Map assets to CIA; bid confidentiality, integrity of price history, availability during bidding deadlines.	[ ] Pending
Secure Design Principles	Roles, bid reveal rules, contact-detail release.	Least privilege, minimal disclosure, separation of duties (officer vs admin), fail-safe defaults.	[ ] Pending
Threat Modeling	Data flows across frontend, API, DB, SMS gateway and image storage.	Data-flow diagram with trust boundaries; threat list per component.	[ ] Pending
Threat Modeling Methodology	Login/OTP, bidding and order flows.	STRIDE per element; risk ranking (e.g., DREAD) with mitigations.	[ ] Pending
Attackers	Shill bidders, middlemen, insiders, external hackers, scrapers.	Attacker profiles and abuse cases (bid manipulation, scraping, account takeover).	[ ] Pending
Security Testing	Login/OTP, bidding API, listings, uploads.	Access-control and deadline tests, rate-limit tests, Postman tests, OWASP ZAP scan, report.	[ ] Pending

Additional topics will be added as they are covered in class.